

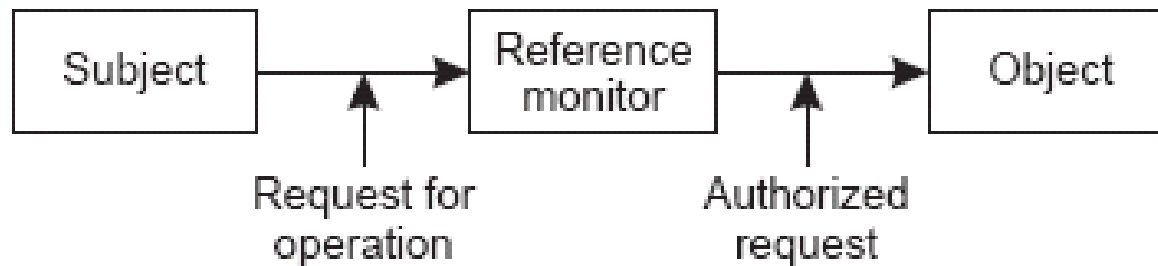
IA 124: INTRODUCTION TO IT SECURITY



Lecture: 07

Access Controls (b)

(Authorization)



ACCESS CONTROL *(ISSUES)*

- ❖ The term **Access Control** actually refers to the control over access to system resources **after** a user's account credentials and identity have been authenticated and access to the system granted.
 - ✓ For example, a particular user, or group of users, might only be permitted access to certain files after logging into a system, while simultaneously being denied access to all other resources.
- ❖ Access Control controls how users and systems communicate and interact with one another.
 - ✓ Access controls give organizations the ability to control, restrict, monitor, and protect resource availability.
 - ✓ They protect the systems and resources from unauthorized access and can be a component that participates in determining the level of authorization after an authentication procedure has successfully completed.
 - ✓ **User** permissions and rights to the system may be based on their identity, clearance, and/or group memberships.

Why access control?

- ❖ The access control is needed to preserve the three tenets of information security; confidentiality, Integrity and Availability
- ❖ The information is not disclosed to unauthorized persons or processes thus preserving **confidentiality**.
- ❖ **Integrity** is preserved through:
 - ✓ The prevention of the modification of information by unauthorized personnel
 - ✓ The preservation of unauthorized or unintentional modification of information by authorized personnel
 - ✓ Preservation of internal and external consistency
- ❖ The system's authorized users have timely and uninterrupted access to the information in the system thus preserving **Availability**.

ACCESS CONTROL (*ISSUES*)

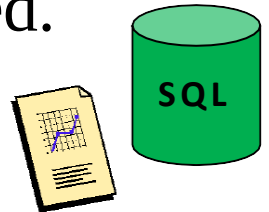
❖ **Subject:** An entity capable of accessing objects.

- ✓ Can be a user, program, or process that accesses an object to accomplish a task.
- ✓ When a program accesses a file, the program is the subject and the file is the object.
- ✓ For a subject to be able to access a resource, it must be identified, authenticated, authorized, and should be held accountable for its actions.



❖ **Object:** A passive entity to which access is controlled.

- ✓ **Operating System:** Files or Directories
- ✓ **Database:** Columns, Rows, Tables, or Views
- ✓ **Computer program**
- ✓ **Memory**
- ✓ **Printer**, etc.



❖ **Access right:** The way in which an object is accessed by a subject.

- ✓ **Applications:** Read, Write, Execute
- ✓ **Database:** Update, Insert, Append, Delete
- ✓ **Reports:** Create, View, Print
- ✓ **Locks:** Open, Close

ACCESS CONTROL *(ISSUES)*

AAA

- ❖ **Authentication:** verifying a claim of identity
- ❖ **Authorization:** verifying a claim of permission
- ❖ **Audit:** verifying the (non) occurrence of previous actions

- ❖ The verification of access rights is **access control**
 - ✓ **Permission/granting of access right to a resource is called authorization.**
 - ✓ These two terms are often used interchangeably

Authorization

- ❖ **Authorization:** Determines that the proven identity has some set of characteristics associated with it that gives it the right to access the requested resources.
 - ✓ Is a core component of every operating system and established whether a user is authorized to access a particular resource and what actions he is permitted to perform on the resource.
 - ✓ Granting access rights to subjects should be based on the level of trust a company has in a subject and the subject's need to know.
- ❖ **Authorization:** It is a process by which the principal is either granted access or disallowed to protected resources according to **Access criteria**.
 - ✓ Only the trusted principal can be granted secure access.

Authorization: Access Criteria

Access criteria can be broken up into:

- ❖ **Roles:** Is an efficient way to assign rights to a type of user who performs a certain task.
 - ✓ This role can be based on job assignment or function.
- ❖ **Groups:** Is an effective way to assign access control rights.
 - ✓ If several users require the same type of access to information and resources, putting them into a group and then assigning rights and permissions to that group is easier to manage than assigning rights and permissions to every individual.
 - ✓ For example, the Finance group can be granted Read and Write permissions for a file named Payroll.dat.
- ❖ **Location (physical or logical):** Can be used to restrict access to resources.
 - ✓ Is implemented on several server configurations to restrict unauthorized individuals from being able to get in and reconfigure the server remotely. Usually done through network address restrictions.
- ❖ **Time (temporal isolation):** Restrict the times that certain actions or services can be accessed.
- ❖ **Transaction Types:** Can be used to control what data is accessed during certain types of functions and what commands can be carried out on the data.

Authorization

Authorization concepts to keep in mind:

- ❖ **Authorization Creep:** When an employee works for a company over time and moves from one department to another and assigned new access rights and permissions without the old permissions being reviewed and removed. **Job recategorization**
- ❖ **Access Control Lists (ACLs):** A list of subjects that are authorized to access a particular object. Typically, the types of access are read, write, execute, append, modify, delete, and create.
- ❖ **Need to know principle:** It is based on the concept that individuals should be given access only to the information that they absolutely require in order to complete their job duties. **Need to know** limits who has access, while **least privileged** restricts what they can do (view, edit, execute,...)

Authorization

Authorization concepts to keep in mind: Security Principles

- ❖ Need to know
- ❖ Least privilege
- ❖ Separation of duties
- ❖ Job rotation
- ❖ Layered security

Security Principles

Least privilege

- ❖ Least privilege means a subject (user, application, or process) should have only the necessary rights and privileges to perform its task with no additional permissions.
 - ✓ Users should only have the level of permissions and rights for those resources that is required to carry out the exact operations they need for their jobs and no more.
- ❖ By limiting an object's privilege, we limit the amount of harm that can be caused.
- ❖ Restricts what they can do (view, edit, execute,...)

Security Principles

Separation of duties (SoD) (also known as "**Segregation of duties**")

- ❖ Is the concept of having more than one person required to complete a task.
- ❖ High-value or high-risk tasks require two or more different individuals to complete
- ❖ Examples
 - ✓ Open a bank vault
 - ✓ Issue an arrest warrant
 - ✓ Provision a privileged-access computer account
 - ✓ Change a firewall rule
- ❖ No single individual can abuse the system.
- ❖ Potential drawback is the cost.
 - ✓ **Time** – Tasks take longer
 - ✓ **Money** – Must pay two people instead of one

Security Principles

Job Rotation

- ❖ The rotation of individuals through different tasks and duties in the organization's IT department.
- ❖ The individuals gain a better perspective of all the elements of how the various parts of the IT department can help or hinder the organization.
- ❖ Prevents a single point of failure, where only one employee knows mission critical job tasks.
 - ✓ Reduces monotony, risk
- ❖ Reduces likelihood that employees will perform inappropriate or illegal actions if they fear being caught when next job rotation occurs

Security Principles

Layered Security

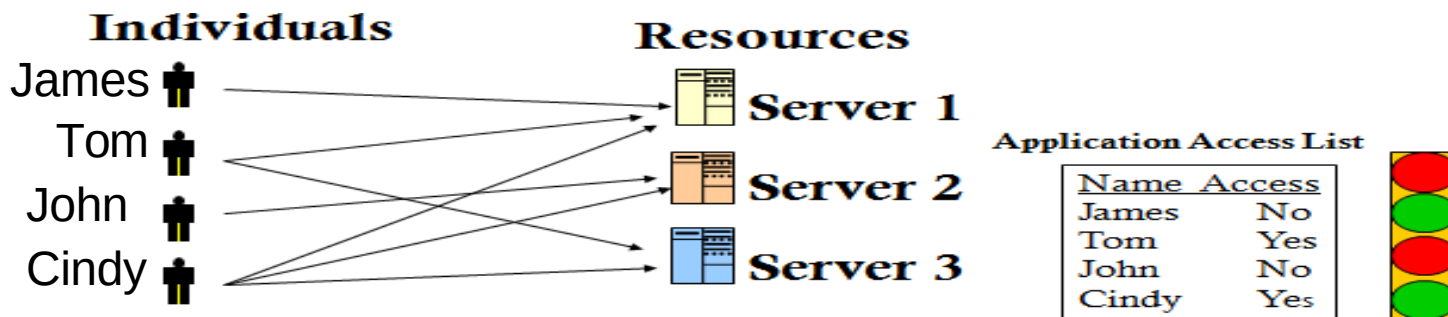
- ❖ Layered security implements different access controls and utilizing various tools and devices within a security system on multiple levels.
- ❖ Compromising the system would take longer and cost more than its worth.
- ❖ Potential downside is the amount of work it takes to create and then maintain the system.

Access Control Models

- ❖ Access control models are generally concerned with whether subjects can access objects and how this access can occur.
- ❖ Access control models are usually seen as frameworks for implementing and ensuring the integrity of security policies that mandate how information can be accessed and shared on a system and how this access can occur.
- ❖ **Three Main Types**
 - ✓ **Discretionary Access Control (DAC)**
 - ✓ **Mandatory Access Control (MAC)**
 - ✓ **Non-Discretionary (Role Based Access Control)**

Discretionary Access Control (DAC)

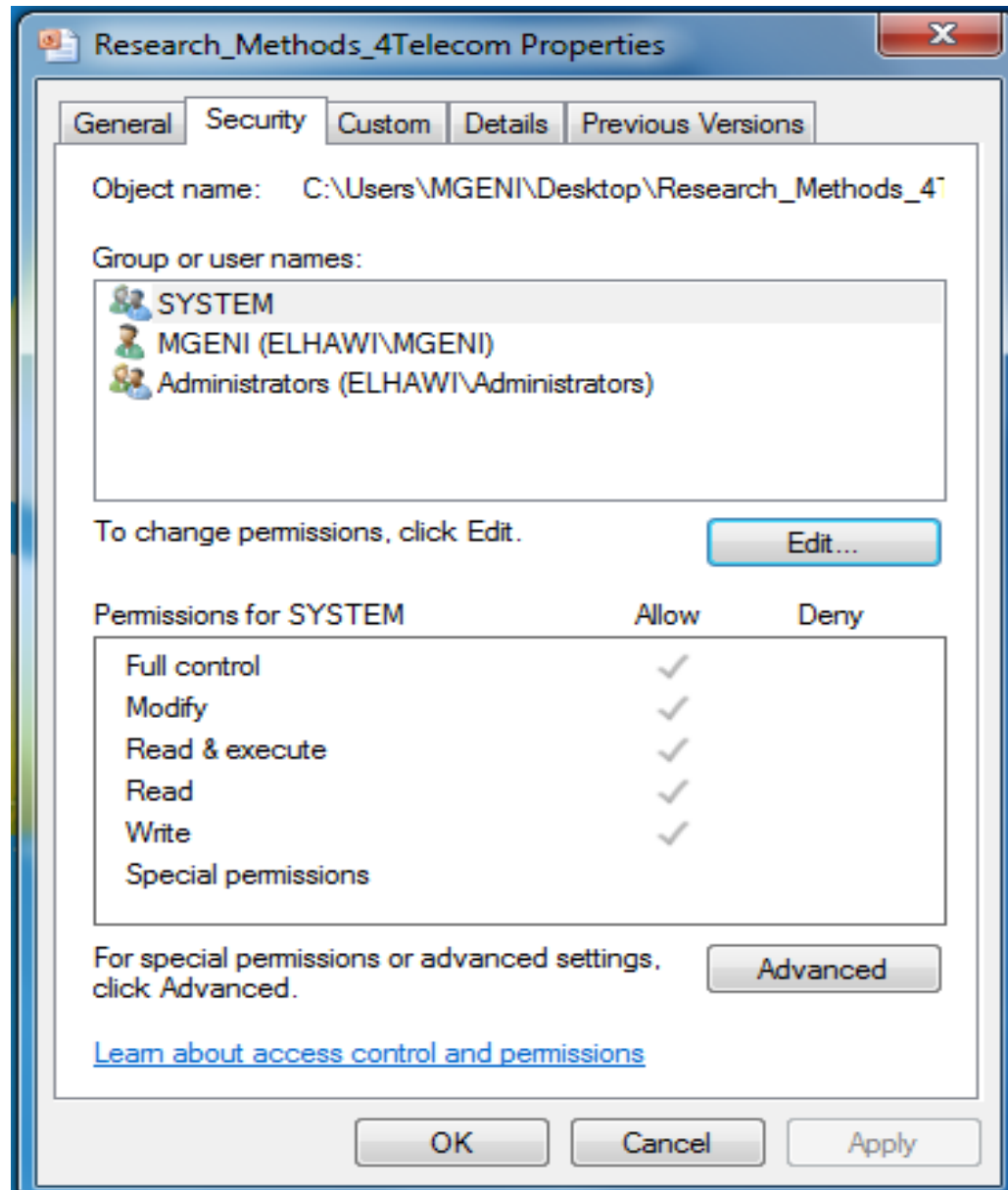
- ❖ In Discretionary Access Control (DAC), the owner of the object specifies which subjects can access the object.
 - ✓ This model is called discretionary because the control of access is based on the discretion (wish) of the owner.
- ❖ The most common implementation of DAC is through *Access Control List (ACL)* which are dictated and set by the owners and enforced by the operating system.
 - ✓ Access control list; lists users and their permitted access right
 - ✓ Each object on a DAC based system has an ACL associated with it.
 - ✓ An ACL contains a list of users and groups to which the user has permitted access together with the level of access for each user or group.
 - ✓ For example, *User A* may provide read-only access on one of the files to *User B*, read and write access on the same file to *User C* and full control to any user belonging to *Group 1*



Discretionary Access Control (DAC)

- ❖ DAC systems grant or deny access based on the identity of the subject. The identity can be a user identity or group membership (Hence; Identity based access control).
 - ✓ Through the user access control procedure (log on), a user can be identified to the system.
 - ✓ Associated with each user, there can be a profile that specifies permissible operations and file accesses.
- ❖ DAC is typically the default access control mechanism for most desktop operating systems; Linux, Windows, etc.
 - ✓ In these operating systems, when you create a file, you decide what access privileges you want to give to other users; when they access your file, the operating system will make the access control decision based on the access privileges you created.
 - ✓ When you look at the properties of a file or directory and you see the choices that allow you to control which users can have access to this resource and to what degree, you are witnessing an instance of ACLs enforcing a DAC model.
 - ✓ DACs can be applied to both the directory tree structure and the files it contains.

Discretionary Access Control (DAC)



Mandatory Access Control (MAC)

- ❖ Unlike Discretionary Access Control (DAC) where each user controls the access to their own data, In Mandatory Access Control (MAC), access to system resources (objects) is controlled by the operating system (under the control of a system administrator configured settings).
- ✓ In mandatory access control (MAC), the system (and not the users) specifies which subjects can access specific data objects.
- ✓ It is not possible under MAC enforcement for users to change the access control of a resource.
- ✓ Operating systems enforce the system's security through the use of **security labels**.

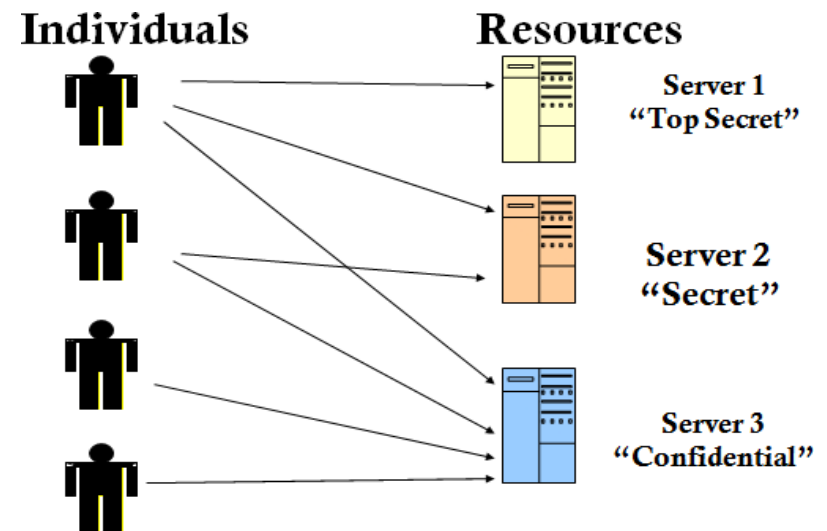
Mandatory Access Control (MAC)

- ❖ In MAC model, Access control is based on a **security labeling system**.
- ❖ Security label/**sensitivity labels** are made up of a **classification** and **Categories/clearances**;
 - ✓ **Classification** indicates the security level of object (Top Secret, Secret, Confidential etc.)
 - ✓ **Categories/clearances**; enforce need to know rules (which is essentially an indication of the management level, department or project to which the object is available).
- ❖ MAC mechanism assign security **clearances** to each **Users (subject)** and assign security levels (**classifications**) to all **resources (object)** and ensure that all users only have **access** to that data for which they have a clearance.
 - ✓ When the system is making an access control decision, it tries to match the clearance of the subject with the classification of the object.
 - ✓ Users have access to data classified equal and lesser than their own status.
 - ✓ For example, if a user has a security clearance of secret, and he requests a data object with a security classification of top secret, then the user will be denied access because his clearance is lower than the classification of the object.



Mandatory Access Control (MAC)

- ❖ MAC focuses on controlling disclosure of information by assigning security levels to objects and subjects, limiting access across security levels, and the consolidation of all classification and access controls into the system.
 - ✓ The MAC model is usually used in environments where confidentiality is of utmost importance, such as a military institution.
 - ✓ Examples of the MAC-based commercial systems are Security-Enhanced Linux (**SE Linux**) and Trusted Solaris.
- ❖ Mandatory Access Control is by far the most secure access control environment compared to DAC but does not come without a price.
- ❖ Firstly, MAC requires a considerable amount of planning before it can be effectively implemented.
- ❖ Once implemented it also imposes a high system management overhead due to the need to constantly update object and account labels to accommodate new data, new users and changes in the categorization and **classification** of existing users.

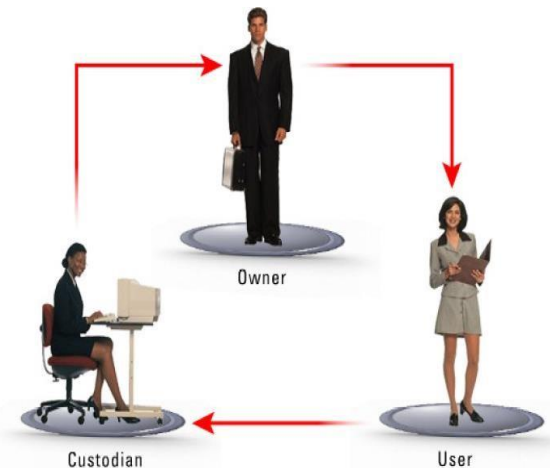


Data Classification

- ❖ **Data classification** is the process of organizing **data** into categories based on its level of sensitivity and the impact to the organization if that data disclosed, altered or destroyed without authorization.
 - ✓ Data and information assets are classified respective of the risk of unauthorized disclosure
 - ✓ The classification of data helps determine what baseline security controls are appropriate for safeguarding that data.
 - ✓ A well-planned **data classification** system makes essential **data** easy to find and retrieve.
 - ✓ This can be of particular importance for risk management, legal discovery, and compliance.

- ❖ **Data Classification: Roles and Responsibilities**

- ✓ **Owners:** Determine security requirements
- ✓ **Custodians:** Manage security based on requirements
- ✓ **Users:** Access as allowed by security requirements



Data Classification

- ❖ Data owners are responsible for defining the security level of the data.
- ❖ Not all information has the same value
 - ✓ Need to evaluate value based on CIA
- ❖ Value determines protection level
 - ✓ Protection levels determine procedures
- ❖ Labeling informs users on handling
- ❖ The following include the major classification criteria:
 - ✓ **Value:** Number one criteria, if it is valuable it should be protected
 - ✓ **Age:** Value of data lowers over time, automatic de-classification
 - ✓ **Useful life:** If the information is made obsolete it can often be de-classified
 - ✓ **Personal Association:** If the data contains personal information it should remain classified
- ❖ Data owner reviews classification level regularly for appropriateness of classified data.
- ❖ The **two common classification** schemes exist:
 - ✓ **Government/Military Classification**
 - ✓ **Commercial/Business/Private Sector Classification**

Government/Military Data Classification

- ❖ Classified information is material that a government body claims is sensitive information that requires protection of Confidentiality, Integrity, and its Availability (the goal of information security).
- ❖ Data classification reflects the level of impact to the government if confidentiality, integrity or availability is compromised.
- ❖ Documents and other information assets in governments are typically marked with one of several (hierarchical) levels of sensitivity from highest to lowest as follows:
 1. **Top secret**
 2. **Secret**
 3. **Confidential**
 4. **Sensitive but Unclassified (SBU)**
 5. **Unclassified**

Government/Military Data Classification

- ❖ **Top Secret:** Disclose of top Secret data would cause severe damage to national security.
- ❖ **Secret:** Disclose of secret data would cause serious damage to national security. This data is considered less sensitive than data classified as top secret.
- ❖ **Confidential:** Confidential data is usually data that is exempt from disclose under laws but is not classified as national security data.
- ❖ **Sensitive but Unclassified (SBU):** SUB data is data not considered vital to national security, but its disclose would do some harm. Many agencies classify data they collect from citizens as UBS.
- ❖ **Unclassified:** Unclassified is data that has no classification or is not sensitive.

Government/Military Data Classification

- ❖ The classifications of **confidential**, **secret**, and **top secret** are collectively known or labeled as **classified**.
 - ✓ Thus, the term classified is generally used to refer to any data that is ranked above the **sensitive but unclassified (SBU)** level.
- ❖ The implementation of the classification is based on laws, policies, and executive directives.
 - ✓ The choice of level is often on an impact assessment; governments often have their own set of rules which include the levels, rules on determining the level for an information asset, and rules on how to protect information classified at each level.
- ❖ Access is restricted by law or regulation to particular groups of people, and mishandling can incur criminal penalties and loss of respect.

Government/Military Data Classification

- ❖ Data classification reflects the level of impact to the government if confidentiality, integrity or availability is compromised. As the total potential impact to the government increases from Low to High, the classification of data should become more restrictive moving from Unclassified to Top Secret.

Unclassified  **Top Secret**

	POTENTIAL IMPACT		
Security Objective	LOW	MODERATE	HIGH
Confidentiality Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.	The unauthorized disclosure of information could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals.	The unauthorized disclosure of information could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals.	The unauthorized disclosure of information could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals.
Integrity Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.	The unauthorized modification or destruction of information could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals.	The unauthorized modification or destruction of information could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals.	The unauthorized modification or destruction of information could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals.
Availability Ensuring timely and reliable access to and use of information.	The disruption of access to or use of information or an information system could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals.	The disruption of access to or use of information or an information system could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals.	The disruption of access to or use of information or an information system could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals.

Commercial/Business/Private Sector Data Classification

- ❖ Classification of commercial or nongovernment organization does not have a set standard.
 - ✓ The classification used is dependent on the overall sensitivity of the data and the levels of confidentiality desired.
 - ✓ Additionally, a nongovernment organization might consider the integrity and availability of data in its classification model.
 - ✓ Some organizations use two types of classification: **Confidential** and **Public**.
 - ✓ For others, a higher granularity might be necessary.
 - ✓ Typical list of classification that can be used for commercial organizations, from highest to lowest.

1. Sensitive	4. Proprietary
2. Confidential	5. Public
3. Private	

Commercial/Business/Private Sector Data Classification

- ❖ **Sensitive:** data that is to have the most limited access and required a high degree of integrity. This is typically data that will do the most damage to the organization if disclosed.
- ❖ **Confidential:** Data that might be less restrictive within the company but might cause damage if disclosed.
- ❖ **Private:** Private data is usually compartmental data that might not do the company damage but must be keep private for other reasons. Human resources data is one example of data that can be classified as private.
- ❖ **Proprietary:** Proprietary data is data that is disclosed outside the company on a limited basis or contains information that could reduce the company's competitive advantage, such as the technical specifications of a new product.
- ❖ **Public:** Public data is the least sensitive data used by the company and would cause the least harm if disclosed. This could be anything from data used for marketing to the number of employees in the company.

Non-Discretionary (Role Based) Access Control Models

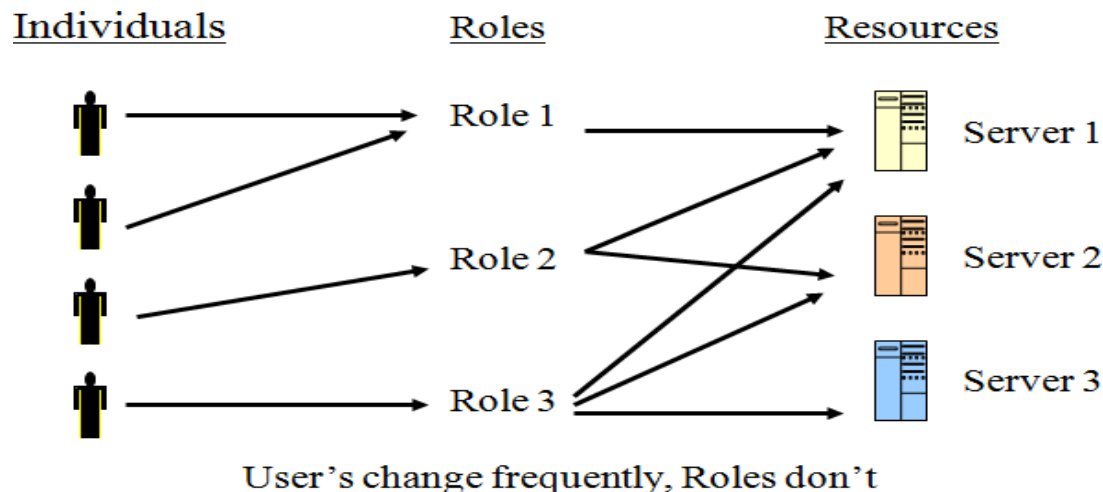
- ❑ **Role Based Access Control (RBAC):** Permission associated with roles and users assigned to appropriate roles
- ❖ A **user** (typically a human being) has access to an object based on the assigned role.
- ❖ **Roles** are defined based on job title/functions.
- ❖ Permissions are defined based on job authority and responsibilities within a job function.
- ❖ Operations on an object are invoked based on the permissions.
 - ✓ File system operations: read, write and execute
 - ✓ DBMS operations: insert, delete, append and update
- ❖ The object is concerned with the user's role and not the user.
- ❖ RBAC is the best system for a company that has high employee turnover.
- ❖ RBAC is currently used in Database management systems, Security management and network operating system

Non-Discretionary (Role Based) Access Control Models

- ❖ Essentially, RBAC assigns permissions to particular roles in an organization. Users are then assigned to that particular role.
 - ✓ For example, an accountant in a company will be assigned to the *Accountant* role, gaining access to all the resources permitted for all accountants on the system.
 - ✓ Similarly, a software engineer might be assigned to the *developer* role.
- ❖ User under RBAC may only be assigned a single role in an organization.
 - ✓ There is no way to provide individual users additional permissions over and above those available for their role.
 - ✓ The accountant described above gets the same permissions as all other accountants, nothing more and nothing less.

Non-Discretionary (Role Based) Access Control Models

- ❖ A **role-based access control** (RBAC) model, also called nondiscretionary access control, uses a centrally administered set of controls to determine how subjects and objects interact.
- ❖ It is referred to as nondiscretionary because assigning a user to a role is unavoidably imposed.
- ❖ The RBAC approach simplifies access control administration by allowing permissions to be managed in terms of user job roles.
- ❖ This type of model allows access to resources to be based on the role the user holds within the company.



DAC vs MAC vs RBAC

Model	Access Control Owner	Sec Policy enforced by
DAC	Data Owners	ACL
MAC	Operating Systems	Security Labels
RBAC	Administrator	Roles/ Functional Position

Access Control Techniques

❖ There are a number of different access controls and technologies available to support the different models.

1. **Rule Based Access Control**
2. **Constrained User Interfaces**
3. **Access Control Matrix**
4. **Content Dependent Access Control**
5. **Context Dependent Access Control**

Access Control Techniques (1)

- ❖ ***Rule based access control*** uses specific rules that indicate what can and cannot happen between a subject and an object.
- ❖ Before a subject can access an object in a certain circumstance, it must meet a set of predefined rules.
- ❖ Rule based access control is not necessarily identity based; rules apply to all users across the board, no matter what their identity is. (The DAC model is identity based).
- ❖ Traditionally, rule based access control has been used in MAC systems as an enforcement mechanism of the complex rules of access that MAC systems provide; today, rule based access is used in other types of systems and applications as well (e.g., routers and firewalls).

Access Control Techniques (2)

- ❖ **Constrained User Interfaces:** Restrict user's access abilities by not allowing them certain types of access, or the ability to request certain functions or information
- ❖ Limits the user's environment within the system, thus limiting access to objects.
- ❖ **Three major types**
 - ✓ **Menus and Shells**
 - ✓ **Database Views**
 - ✓ **Physically Constrained Interfaces**

Access Control Techniques (2)

Three major types of Constrained User Interfaces:

❖ Menus and Shells

- ✓ The options that a user is given are the commands that they can execute.
- ✓ A *shell* is a type of virtual environment within a system; it is the user's interface to the operating system and works as a command interpreter

❖ Database Views

- ✓ Are mechanisms used to restrict user access to data that is contained in the database.

❖ Physically Constrained Interfaces

- ✓ Can be implemented by providing only certain keys on a keypad or certain touch buttons on a screen. (e.g., ATM machine views).

Access Control Techniques (3)

❖ Access Control Matrix

- ✓ Is a table of subjects and objects indicating what actions individual subjects can take upon individual objects.
- ✓ Matrices are data structures that programmers implement as table lookups that will be used and enforced by the operating system.
- ✓ Access control matrix consists of triple parts such as **subject**, **object**, and **Access right**.
- ✓ General this technique used to control access in DAC.

❖ **Access control matrix** do not allow unauthorized users or subjects to use system protection resources

	Program1	...	SegmentA	SegmentB
Process1	Read Execute		Read Write	
Process2				Read
.				
.				
.				

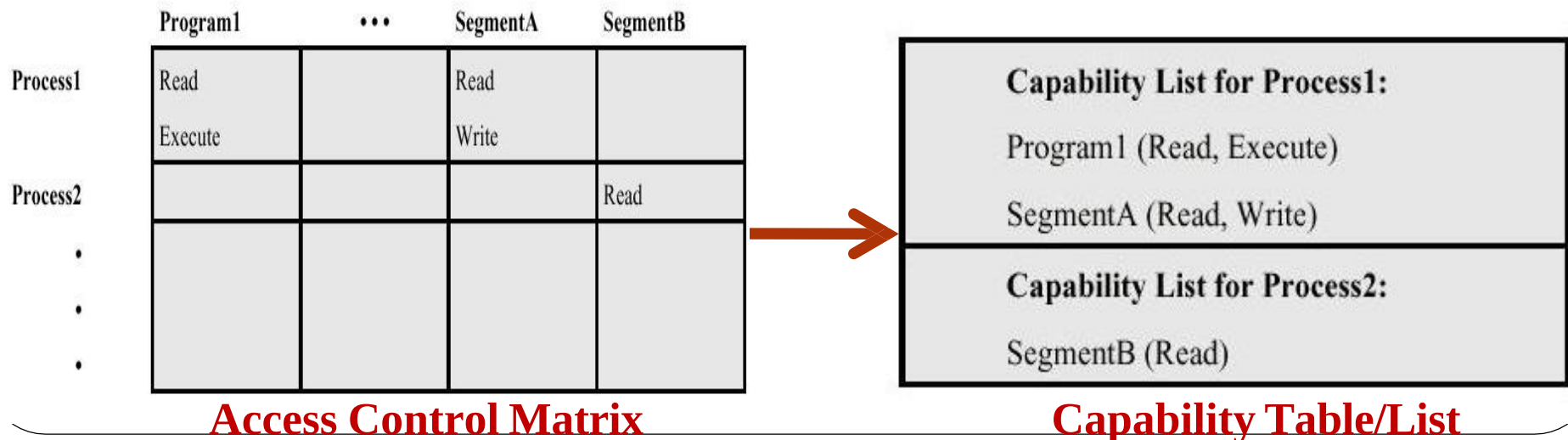
❖ **Two types** (derivative forms of access control matrix)

1. Capability Table (bound to a subject, Decomposition of the matrix by rows)
2. Access Control List (bound to an object, Decomposition of the matrix by columns)

Access Control Techniques (3)

Access Control Matrix

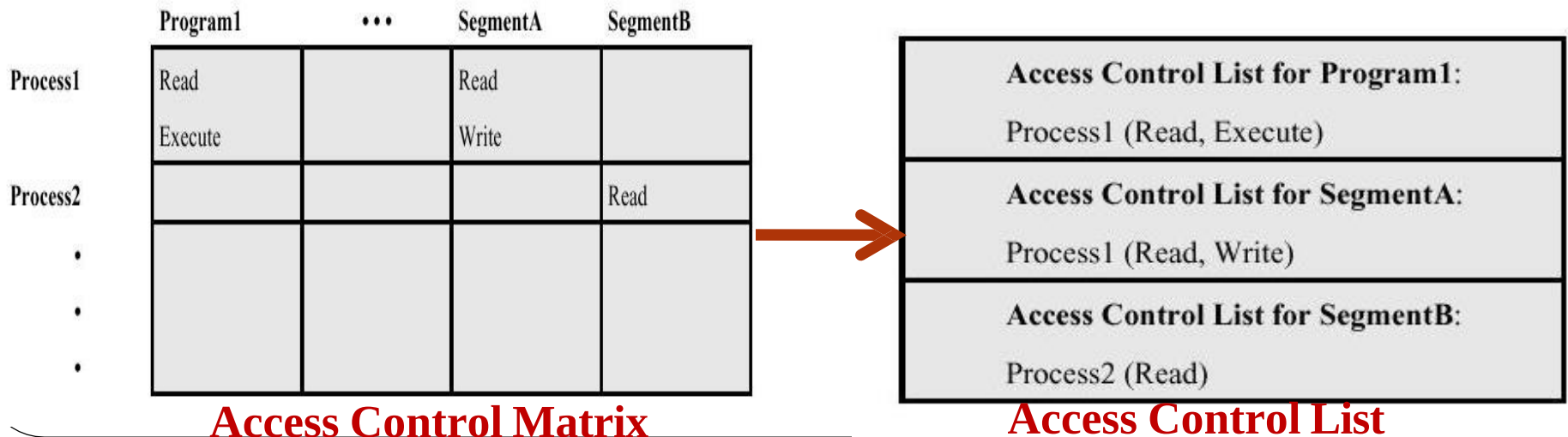
- ❖ **Capability table** (bound to a subject): Specifies the access rights a certain subject possess pertaining to certain objects.
- ❖ **Capability table /List:** Decomposition of the Access Control matrix by **rows**
- ❖ Bounded to a subject and indicates what objects that subject can access.
- ❖ A capability can be in the form of a token, ticket, or key.



Access Control Techniques (3)

Access Control Matrix

- ❖ **Access Control List (ACL)**; bound to an object: Lists of subjects that are authorized to access a specific object and they define what level of authorization is granted. Authorization can be specified to an individual or group.
- ❖ **Access Control List:** Decomposition of the Access Control matrix by columns
- ❖ Access control list; lists users and their permitted access right.
- ❖ ACLs map values from the access control matrix to the object.



Access Control Techniques (4)

- ❖ **Content Dependent Access Control:** Access to an object is determined by the content within the object.
- ❖ With content based access control, access to objects is determined by the content within the object.
- ❖ Bases access decisions on the sensitivity of the data, not solely on subject's identity.
 - ✓ This is often used in databases. E.g., the content of the **database** fields dictates which users can see specific information within the database tables.
 - ✓ Content dependent filtering is used when corporations employ **email filters** that look for specific strings, such as “confidential,” “top secret,” etc.

Access Control Techniques (5)

- ❖ **Context Based Access Control:** Makes access decision based on the context of a collection of information rather than content within an object.
 - ✓ Bases access decisions on the state of the situation, not solely on identity or content sensitivity.
 - ✓ A system that is using context dependent access control “reviews the situation” and then makes a decision.
- ❖ **Context based access control** differs from content dependent access control in that it makes access decisions based on the context of a collection of information rather than on the sensitivity of the data.
- ❖ For example, firewalls make context based decisions when they collect state information on a packet before allowing it into the network.

Access Control Administration

- ❖ First an organization must choose the access control model (DAC, MAC, RBAC).
- ❖ Then the organization must select and implement different access control technologies/techniques.
 1. Rule Based Access Control
 2. Constrained User Interfaces
 3. Access Control Matrix
 4. Content Dependent Access Control
 5. Context Dependent Access Control
- ❖ Access Control Administration comes in two basic forms:
 1. **Centralized**
 2. **Decentralized**

Access Control Administration (1)

Centralized Access Control Administration:

- ❖ One entity is responsible for overseeing access to all corporate resources.
- ❖ Provides a consistent and uniform method of controlling access rights.
 - ✓ Protocols: Agreed upon ways of communication
 - ✓ Attribute Value Pairs: Defined fields that accept certain values.
- ❖ Types of Centralized Access Control
 - ✓ **RADIUS**
 - ✓ **TACACS**
 - ✓ **Diameter**

Access Control Administration (1)

Centralized Access Control Administration: RADIUS

- ❖ Remote Authentication Dial In User Service.
- ❖ Is a client/server authentication protocol and authenticates and authorizes remote users.
- ❖ Most ISPs today use Radius to authenticate customers before they are allowed to access the Internet.
- ❖ Radius is an open protocol and can be used in different types of implementations.
- ❖ Uses UDP as a transport protocol .
- ❖ **Only encrypts the user's password as it is being transmitted from Radius client to the radius server.**
- ❖ Is appropriate protocol when simplistic username/password authentication can take place and users only need an “accept” or “deny” for obtaining access.

Access Control Administration (1)

Centralized Access Control Administration: TACACS

- ❖ Terminal Access Controller Access Control System
- ❖ Uses TCP as a transport protocol.
- ❖ Encrypts all user data and does not have the vulnerabilities that are inherent in the radius protocol.
- ❖ Presents true AAA (Authentication, Authorization, and Accounting) architecture.

Centralized Access Control Administration: Diameter

- ❖ A protocol that has been developed to build upon the functionality of radius and overcome many of its limitations
- ❖ Diameter provides the common AAA (Authentication, Authorization, and Accounting) and security framework that different services can work within.

Access Control Administration (2)

❖ **Decentralized Access Control Administration:**

- ❖ Gives control of access to the people who are closer to the resources
 - ✓ the people who may better understand who should and should not have access to certain files, data, and resources.
- ❖ In this approach it is often the functional manager who assigns access control rights to employees.
- ❖ Changes happen faster through this type of administration because not just one entity is making changes for the whole organization.
- ❖ Because no single entity controls access as a whole, different managers and departments can practice security and access controls in different ways.
- ❖ Has no methods for consistent control, lack of proper consistency.
- ❖ An example is a peer-to-peer working group.

Access Control Methods

- ❖ Access controls can be implemented at various layers of an organization, network, and individual systems
- ❖ Three broad categories: (*Discussed in part A*)
 - ✓ Administrative
 - ✓ Physical
 - ✓ Technical (aka Logical)

Operational Model of Computer Security

- ❖ Protection = Prevention

 - ✓ Previous model

- ❖ Protection = Prevention + (Detection + Response)

 - ✓ Includes operational aspects

Operational Model of Computer Security

❖ Protection = Prevention

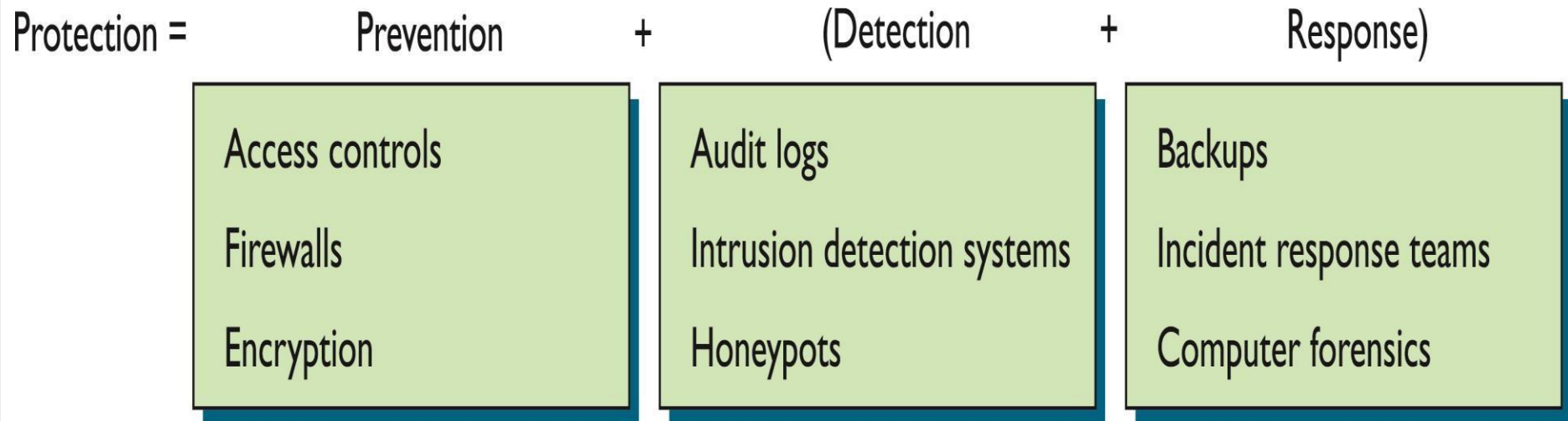
- ✓ Previous model
- ✓ Previously, the focus of security was prevention. It was reasoned that if unauthorized access to computer systems and networks was prevented, security had been achieved.
- ✓ As security attacks have evolved and unauthorized users have found multiple ways to bypass these safeguards has led to a modification of the basic security model:
Protection = Prevention.

Operational Model of Computer Security

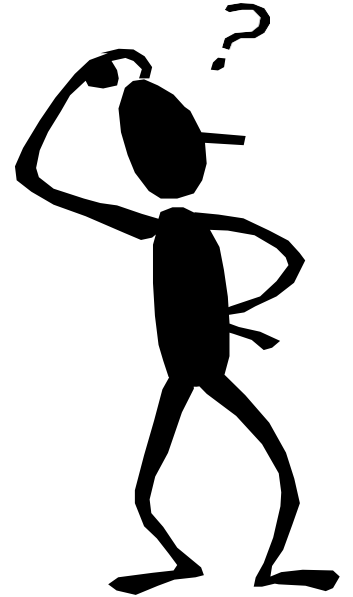
❖ **Protection = Prevention + (Detection + Response)**

- ✓ The updated model is known as The Operational Model of Computer Security and is as follows: Protection = Prevention + (Detection + Response).
- ✓ The modification means that two new elements of security come into play with any security system: detection and response.
- ✓ Detection gives security professionals the ability to be alerted of a threat and response allows for ways to solve the problem before it becomes unmanageable. Every security technique and technology falls into at least one of the elements of this model.

Operational Model of Computer Security



THANK YOU



END

ET 8202: LECTURE 07